

Session v.s. JWT

Sessions

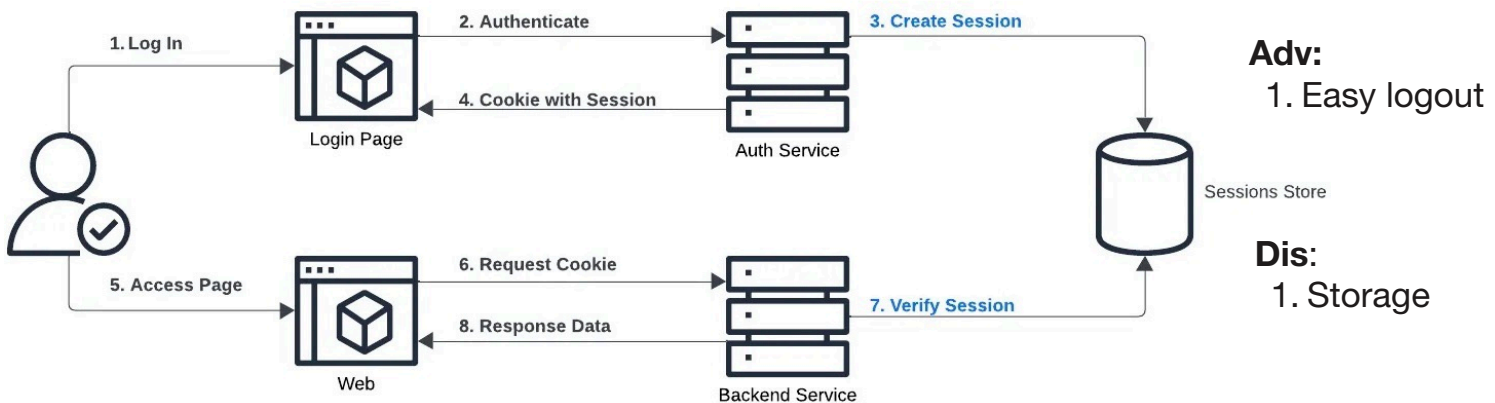
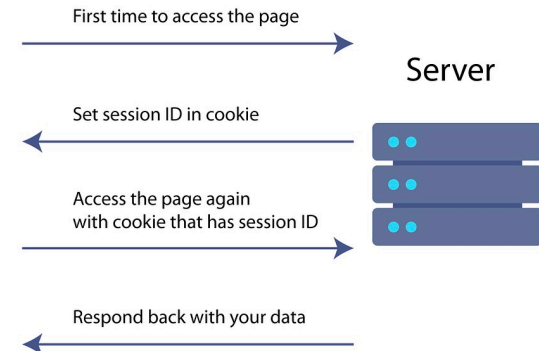
Login Flow (Session)

- User enters **username + password**
- Server **verifies** credentials
- Server creates a **session object**
- Server **stores** this in:
 - Memory (RAM)
 - Redis
 - Database

- Server **sends** sessionId to **browser** as a **cookie**

Every Request

- **Browser** sends: Cookie: sessionId=abc123
- **Server:**
 - **Looks up** sessionId in storage
 - **Retrieves** user data
 - **Authorises** request



JWT (JSON Web token)

Login Flow (JWT)

- User **logs in**
- Server **validates** credentials
- Server **creates JWT & signs** it
- Token is **sent to client**
- Authorisation header or **cookie**

Every Request After Login

- **Authorization:** Bearer <JWT>
- **Server:**
 - **Verifies signature**
 - Checks expiry
 - Reads payload
 - No DB / cache lookup

Structure of a JSON Web Token (JWT)

